

Appendix F Phase 2 Audit Run Pack and Capture Log

F.1 Purpose

This appendix records how the Phase 2 runs were carried out, and captures every output exactly as the model returned it.

It also outlines the a) LLM conditions applied when the Phase 2 cross-audits were executed. b) Results of the calibration exercise performed against each model are reported, using two worked examples scored before any live policy was provided. c) The policies each model audited, and the prompt used, are named..

One document code appears in the outputs: RUB-01 is the Policy Evaluation Rubric at Appendix D.

F.2 Phase 2 execution

Phase 2 consisted of six runs that took place on 22 August 2026, which were 2 Calibration runs, one for each model, followed by 4 cross-audits.

Five assembled prompt files had been prepared in advance, and each is named against the run that used it in the capture log below.

The same steps were followed every time.

- Each assembled file was copied whole and pasted into a single message as plain text; nothing was uploaded as a file, and nothing was retyped.
- Runs took place in a fresh session each time, with no earlier conversation, custom instruction, project, saved memory or system prompt in force.
- The first complete response was taken, and no follow-up question was asked.
- Build string, interface, date and time were noted, and the reply was saved to a text file before the next run began.

No run was refused and none was cut short, and no paste had to be split.

F.3 Calibration before the live audits

The rubric in Appendix D, at Section D.2, requires every rater [LLM models and also human reviewers] to score the two worked examples before scoring any live policy provided to them, so that any later difference between raters can be attributed to the policy rather than to the marker. The calibration exercise used the pre-defined reference scorings of 47 for the first worked example and 73 for the second.

The results were recorded in Table F.1, which consolidates what each LLM model returned during the phase 2 calibration stage before any of the four audits were run.

Rater	Extract	Coverage	Accuracy	Proportionality / Enforceability	Area score
ChatGPT	1	13	90	55 / 30	44
ChatGPT	2	46	90	75 / 90	72
Grok	1	13	90	90 / 30	51
Grok	2	47	90	70 / 70	67

Table F.1: Calibration results of LLM models.

The calibration results are discussed at Chapter 4, Section 4.5.

F.4 The four cross-audits

Each model audited only policies written by the other LLM, not its own generated policies. Table F.2 lists the four audits that were executed as part of phase 2, along with the other model's policies each model was given to audit using the master prompt, Prompt C.

Audit	Auditing model	Policy under audit	Master prompt
A(P1a)	Grok	P1a, ChatGPT under Prompt A	Prompt C
A(P1b)	Grok	P1b, ChatGPT under Prompt B	Prompt C
A(P2a)	ChatGPT	P2a, Grok under Prompt A	Prompt C
A(P2b)	ChatGPT	P2b, Grok under Prompt B	Prompt C

Table F.2: The four Phase 2 cross-audits.

F.5 Capture log

F.5.1 Calibration — ChatGPT

Run	Calibration — ChatGPT
Model	ChatGPT
Build	GPT-5.6 Sol
Interface	Web interface
Date and time (BST)	22 August 2026, 01:05 BST
Purpose	Calibration, both worked examples
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Evaluation Rubric and Scoring Guide.docx; Scenario Brief NorthPay.docx
Prompt file used	PROMPT-CAL_Calibration_ASSEMBLED_2026-08-22.txt
Output file	CAL_ChatGPT_PromptCAL_2026-08-22.txt
Refusal or truncation	None
Non-default settings	None

Verbatim output:

Extract 1

Sub-requirement	Rating	Points	Evidence note
-----	-----:	-----:	

8.1.1	Partially addressed	1	“maintain strong authentication controls”; documented, current, operational and communicated procedures are not required.
8.1.2	Partially addressed	1	“The IT function is responsible”; activities are not assigned or required to be understood.
8.2.1	Partially addressed	1	“appropriate access credentials”; unique individual IDs are not required.
8.2.2	Not addressed	0	Absent.
8.2.4	Not addressed	0	Absent.

8.2.5		Not addressed		0		Absent.	
8.2.6		Not addressed		0		Absent.	
8.2.7		Not addressed		0		Absent.	
8.2.8		Not addressed		0		Absent.	
8.3.1		Partially addressed		1		“appropriate access credentials”; permitted authentication factors and universal authentication are not testable.	
8.3.3		Not addressed		0		Absent.	
8.3.4		Not addressed		0		Absent.	
8.3.5		Not addressed		0		Absent.	
8.3.6		Partially addressed		1		“Passwords shall be strong”; minimum length and alphabetic/numeric parameters are absent.	
8.3.7		Not addressed		0		Absent.	
8.3.8		Not addressed		0		Absent.	
8.3.9		Partially addressed		1		“changed regularly”; neither 90 days nor dynamic access analysis is specified.	
8.3.11		Not addressed		0		Absent.	
8.4.1		Partially addressed		1		“Multi-factor authentication shall be used where appropriate”; administrative non-console scope is absent.	
8.4.2		Partially addressed		1		Same wording; all non-console access into the CDE is not required.	
8.4.3		Partially addressed		1		Same wording; external remote access capable of impacting the CDE is not specified.	
8.6.1		Not addressed		0		Absent.	
8.6.2		Not addressed		0		Absent.	
8.6.3		Not addressed		0		Absent.	

****Checklist total:** 9/72**

****Coverage:** (100 \times 9/72 = 12.5), rounded to ****13******

****Accuracy defects:**** 0. The statements are vague or weaker than the standard, rather than false. "Access shall be reviewed periodically" is an additional control and is not attributed to a particular Requirement 8 sub-requirement.

Criterion	Score	Working
-----	----	

Regulatory coverage	13	Checklist result: 9/72 = 12.5 → 13.
Accuracy	90	No counted defect; highest-band midpoint.
Proportionality and scope fit	55	41–60 band because scope remains generic; midpoint 50, +5 because the controls assume no materially unsupported capability.
Enforceability and clarity	30	21–40 midpoint: "appropriate," "regularly" and "periodically" are untestable, and ownership is assigned only generally to "the IT function."

****Requirement-area score:****

[
 $(13 \times 0.35) + (90 \times 0.25) + (55 \times 0.20) + (30 \times 0.20)$
 =44.05
]

****Rounded score: 44/100****

Extract 2

Sub-requirement	Rating	Points	Evidence note
-----	-----	----	

8.1.1	Partially addressed	1	Ownership and annual review are stated, but procedures being in use and known to affected parties are absent.
8.1.2	Largely addressed	2	The Information Security Manager is assigned ownership; responsibility being understood is not stated.
8.2.1	Fully addressed	3	Unique identifier required before access, with overall ownership assigned.
8.2.2	Largely addressed	2	Approval, time limitation and attribution are specified; documented business justification and identity confirmation are not explicit.
8.2.4	Not addressed	0	Approval and privilege controls for additions and modifications are absent.
8.2.5	Largely addressed	2	"disabled on the last working day" is weaker than immediate revocation upon termination.

8.2.6	Fully addressed	3	Inactive accounts are automatically disabled at 90 days.	
8.2.7	Fully addressed	3	Third-party remote accounts are time-limited and monitored while used.	
8.2.8	Not addressed	0	Absent.	
8.3.1	Partially addressed	1	Password and MFA factors are described, but the universal authentication obligation is not expressly stated.	
8.3.3	Not addressed	0	Absent.	
8.3.4	Not addressed	0	Absent.	
8.3.5	Not addressed	0	Absent.	
8.3.6	Fully addressed	3	Twelve characters plus alphabetic and numeric characters are required.	
8.3.7	Not addressed	0	Absent.	
8.3.8	Not addressed	0	Absent.	
8.3.9	Fully addressed	3	Ninety-day changes or dynamic access analysis are specified.	
8.3.11	Not addressed	0	Absent.	
8.4.1	Fully addressed	3	MFA is required for all non-console administrative access.	
8.4.2	Fully addressed	3	MFA is required for all access into systems connected to the CDE.	
8.4.3	Fully addressed	3	MFA is required for remote access originating outside the corporate network.	
8.6.1	Not addressed	0	Absent.	
8.6.2	Not addressed	0	Absent.	
8.6.3	Partially addressed	1	Periodic password change and complexity are stated generally; targeted-risk-analysis frequency and change upon suspected compromise are absent.	

****Checklist total:** 33/72**

****Coverage:** (100 \times 33/72 = 45.83), rounded to ****46******

****Accuracy defects:** 0. All cited numbers resolve to the stated obligations and the parameters used are from PCI DSS v4.0.1. Correctly cited 7.2.4 and excluded 8.5.1 receive no Requirement 8 checklist credit.**

Criterion	Score	Working
-----	----	

Regulatory coverage	46	Checklist result: 33/72 = 45.83 → 46.
Accuracy	90	No counted defect; highest-band midpoint.
Proportionality and scope fit	75	61-80 band because automatic inactivity disabling assumes a modest capability not stated in the scenario; midpoint 70, +5 because scope otherwise reflects the CDE accurately and uses the existing identity provider.
Enforceability and clarity	90	Highest-band midpoint: obligations have an overall owner, measurable parameters and an annual review cadence; shared-account exceptions have an approver and time limit.

Requirement-area score:

[
 $(46 \times 0.35) + (90 \times 0.25) + (75 \times 0.20) + (90 \times 0.20)$
 =71.60
]

Rounded score: 72/100

F.5.2 Calibration — Grok

Run	Calibration — Grok
Model	Grok
Build	Grok 4.5
Interface	Web interface
Date and time (BST)	22 August 2026, 01:10 BST
Purpose	Calibration, both worked examples
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Evaluation Rubric and Scoring Guide.docx; Scenario Brief NorthPay.docx
Prompt file used	PROMPT-CAL_Calibration_ASSEMBLED_2026-08-22.txt
Output file	CAL_Grok_PromptCAL_2026-08-22.txt

Refusal or truncation	None
Non-default settings	None

Verbatim output:

****EXTRACT 1****

Coverage checklist (24 applicable sub-requirements):

- 8.1.1 Partially addressed (1) — “NorthPay shall maintain strong authentication controls in line with PCI DSS Requirement 8. [...] The IT function is responsible for this policy.”
- 8.1.2 Partially addressed (1) — “The IT function is responsible for this policy.”
- 8.2.1 Not addressed (0) — absent
- 8.2.2 Not addressed (0) — absent
- 8.2.4 Not addressed (0) — absent
- 8.2.5 Not addressed (0) — absent
- 8.2.6 Not addressed (0) — absent
- 8.2.7 Not addressed (0) — absent
- 8.2.8 Not addressed (0) — absent
- 8.3.1 Partially addressed (1) — “Passwords shall be strong and changed regularly. Multi-factor authentication shall be used where appropriate.”
- 8.3.3 Not addressed (0) — absent
- 8.3.4 Not addressed (0) — absent
- 8.3.5 Not addressed (0) — absent
- 8.3.6 Partially addressed (1) — “Passwords shall be strong and changed regularly.”
- 8.3.7 Not addressed (0) — absent
- 8.3.8 Partially addressed (1) — the extract as a whole
- 8.3.9 Partially addressed (1) — “Passwords shall be strong and changed regularly.”
- 8.3.11 Not addressed (0) — absent
- 8.4.1 Partially addressed (1) — “Multi-factor authentication shall be used where appropriate.”
- 8.4.2 Partially addressed (1) — “Multi-factor authentication shall be used where appropriate.”
- 8.4.3 Partially addressed (1) — “Multi-factor authentication shall be used where appropriate.”
- 8.6.1 Not addressed (0) — absent
- 8.6.2 Not addressed (0) — absent
- 8.6.3 Not addressed (0) — absent

Checklist total: 9 points. Coverage = $100 \times 9 \div 72 = 12.5$, rounded to 13.

Accuracy defects: 0.

Regulatory coverage: 13 (the calculated coverage figure).

Accuracy: 90 (0 defects; midpoint of 81–100 band; no movement).

Proportionality and scope fit: 90 (midpoint of 81–100; controls that exist are operable by the two-person function with stated capabilities; no PAN-storage claim; no movement).

Enforceability and clarity: 30 (midpoint of 21–40; wording relies on “appropriate”, “regularly”, “periodically”, “where appropriate”; ownership is the generic “IT function”; no movement).

Requirement-area score = $(13 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (30 \times 0.20) = 51$.

****EXTRACT 2****

Coverage checklist (24 applicable sub-requirements):

8.1.1 Largely addressed (2) — “Ownership: Information Security Manager. Review: annually, or on significant change to the identity provider.”

8.1.2 Largely addressed (2) — “Ownership: Information Security Manager. Review: annually, or on significant change to the identity provider.”

8.2.1 Fully addressed (3)

8.2.2 Largely addressed (2) — “Shared, group and generic accounts are prohibited except where an exception is approved in writing by the Information Security Manager, limited to a stated period, and attributable to an individual (8.2.1, 8.2.2).”

8.2.4 Not addressed (0) — absent

8.2.5 Largely addressed (2) — “Accounts for leavers are disabled on the last working day and removed within five working days.”

8.2.6 Fully addressed (3)

8.2.7 Largely addressed (2) — “Accounts used by third parties for remote support are enabled only for the period needed and monitored while in use (8.2.7).”

8.2.8 Not addressed (0) — absent

8.3.1 Largely addressed (2) — “Passwords are a minimum of 12 characters, contain both numeric and alphabetic characters, and are changed at least once every 90 days unless the account is subject to dynamic access analysis (8.3.6, 8.3.9).”

8.3.3 Not addressed (0) — absent

8.3.4 Not addressed (0) — absent

8.3.5 Not addressed (0) — absent

8.3.6 Fully addressed (3)

8.3.7 Not addressed (0) — absent

8.3.8 Partially addressed (1) — the 8.3 paragraph plus ownership/review sentence

8.3.9 Fully addressed (3)

8.3.11 Not addressed (0) — absent

8.4.1 Fully addressed (3)

8.4.2 Fully addressed (3)

8.4.3 Fully addressed (3)

8.6.1 Not addressed (0) — absent

8.6.2 Not addressed (0) — absent

8.6.3 Not addressed (0) — absent

Checklist total: 34 points. Coverage = $100 \times 34 \div 72 = 47$.

Accuracy defects: 0.

Regulatory coverage: 47 (the calculated coverage figure).

Accuracy: 90 (0 defects; midpoint of 81–100 band; no movement).

Proportionality and scope fit: 70 (midpoint of 61–80; automatic 90-day disable assumes a capability the scenario states does not exist; one step of five).

Enforceability and clarity: 70 (midpoint of 61–80; most stated obligations are testable and owned by the Information Security Manager with an annual review; isolated gaps remain; no further movement).

Requirement-area score = $(47 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (70 \times 0.20) = 67$.

F.5.3 A(P1a) — Grok audits P1a

Run	A(P1a) — Grok audits P1a
Model	Grok
Build	Grok 4.5
Interface	Web interface
Date and time (BST)	22 August 2026, 02:10 BST
Purpose	Cross-audit of P1a
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Evaluation Rubric and Scoring Guide.docx; Scenario Brief NorthPay.docx
Prompt file used	PROMPT-C_Audit-of-P1a_ASSEMBLED_2026-08-22.txt
Output file	A(P1a)_Grok_PromptC_2026-08-22.txt
Refusal or truncation	None
Non-default settings	None

Verbatim output:

**** 1. Mapping ****

Policy provisions map to PCI DSS v4.0.1 sub-requirements as follows (only explicit or clearly intended coverage is listed):

- §1.1 Purpose and application → 12.1.1, 12.1.2
- §1.2 PCI DSS scope → 12.5.1, 12.5.2
- §1.3 Information security responsibilities → 7.1.2, 8.1.2, 10.1.2, 12.1.3, 12.1.4
- §1.4 Supporting policies and procedures → 7.1.1, 8.1.1, 10.1.1
- §2.1 Access control model → 7.2.1, 7.2.2
- §2.2 Access approval → 7.2.3, 8.2.4
- §2.3 Access reviews → 7.2.4
- §2.4 Application and system accounts → 7.2.5, 7.2.5.1
- §2.5 Access to stored cardholder-data repositories → 7.2.6
- §3.1 Unique identities → 8.2.1
- §3.2 Shared and generic credentials → 8.2.2
- §3.3 Account lifecycle → 8.2.4, 8.2.5, 8.2.6
- §3.4 Third-party remote accounts → 8.2.7
- §3.5 Session inactivity → 8.2.8
- §3.6 Authentication factors → 8.3.1, 8.3.3, 8.3.11
- §3.7 Invalid authentication attempts → 8.3.4
- §3.8 Password establishment and reset → 8.3.5, 8.3.6, 8.3.7
- §3.9 Authentication guidance → 8.3.8
- §3.10 Single-factor password authentication → 8.3.9
- §3.11 Multi-factor authentication → 8.4.1, 8.4.2, 8.4.3
- §3.12 Application and system account authentication → 8.6.1, 8.6.2, 8.6.3
- §4.1 Logging and monitoring responsibilities → 10.1.1, 10.1.2
- §4.2 Protection of audit logs → 10.3.1
- §4.3 Daily log reviews → 10.4.1
- §4.4 Other log reviews → 10.4.2, 10.4.2.1
- §4.5 Exceptions and anomalies → 10.4.3
- §4.6 Audit-log retention → 10.5.1
- §4.7 Failure of critical security controls → 10.7.3
- §5.1 Policy management → 12.1.1, 12.1.2
- §5.2 Acceptable use of end-user technology → 12.2.1
- §5.3 Targeted risk analyses → 12.3.1
- §5.4 Customized approach risk analysis → 12.3.2
- §5.5 Cryptographic protocols and cipher suites → 12.3.3
- §5.6 Technology lifecycle review → 12.3.4
- §6.1 Security awareness programme → 12.6.1, 12.6.2
- §6.2 Training and acknowledgement → 12.6.3
- §6.3 Threat awareness → 12.6.3.1
- §6.4 Acceptable-use awareness → 12.6.3.2
- §6.5 Personnel screening → 12.7.1
- §7.1 TPSP register → 12.8.1
- §7.2 Written agreements → 12.8.2

- §7.3 TPSP engagement and due diligence → 12.8.3
- §7.4 Monitoring TPSP PCI DSS status → 12.8.4
- §7.5 Responsibility matrix → 12.8.5
- §8.1 Incident response plan → 12.10.1
- §8.2 Incident response review and testing → 12.10.2
- §8.3 Continuous incident-response availability → 12.10.3
- §8.4 Incident responder training → 12.10.4, 12.10.4.1
- §8.5 Security monitoring alerts → 12.10.5
- §8.6 Lessons learned → 12.10.6
- §8.7 Unexpected PAN discovery → 12.10.7
- §9.1 Operational implementation → 7.1.1, 8.1.1, 10.1.1, 12.1.1
- §9.2 Review and approval → 12.1.2

****2. Findings****

- 7.2.4 (user/third-party account reviews every six months with management acknowledgement): present but weakly enforceable because no named owner or evidence/record format is specified beyond a general statement. Administrative.
- 7.2.5.1 / 8.6.3 / 10.4.2.1 / 12.10.4.1 (targeted risk analyses for periodic reviews and frequencies): required and described, yet no actual analyses exist or are referenced; the policy only mandates their future creation. Administrative.
- 8.2.5 / 8.2.6 (immediate revocation on termination; disable inactive accounts ≤90 days): stated, but the organisation currently has no automatic de-provisioning and performs SaaS removal manually; the policy does not close this operational gap. Technical / Administrative.
- 8.2.8 (15-minute idle re-authentication): stated for all in-scope sessions, including SaaS, yet the order-management platform currently has no timeout while a tab remains open; the policy does not require remediation of that configuration. Technical.
- 8.3.6 (minimum 12-character passwords): correctly requires change from the current 10-character setting, but does not set a completion deadline or owner. Technical.
- 8.4.1-8.4.3 (MFA for all non-console CDE access and remote access): correctly expands beyond the current AWS-console and collaboration-suite enforcement, but provides no implementation owner or target date. Technical.
- 10.4.1 (daily review of security events, CHD/SAD logs, critical components and security-function logs): stated, including outside office hours, yet current practice is shared-mailbox alerts only 08:00–18:00 weekdays and no 24/7 coverage; the policy does not prescribe how the daily obligation will be met. Technical / Administrative.
- 10.5.1 (12-month retention with 3 months immediately available): correctly requires archival beyond the current 90-day SIEM retention, but again lacks owner and timeline. Technical.
- 12.1.3 / 12.1.4 (roles defined and acknowledged; formal executive assignment): CTO is named, Information Security Manager is named, yet job descriptions still omit security responsibilities and no acknowledgement process is detailed. Administrative.
- 12.3.3 (cryptographic inventory and annual review): required, yet the organisation currently tracks certificates only in a spreadsheet and has no algorithm/protocol inventory; the policy does not compel creation of the missing inventory. Technical / Administrative.

- 12.6.3 (training upon hire + annually + acknowledgement + multiple methods + 100 % coverage): stated, but current completion is only 78 % and no role-specific training for dispute handlers or administrators is required. Administrative.
- 12.8.1-12.8.5 (TPSP register, written agreements with security acknowledgements, due diligence, annual compliance monitoring, responsibility matrix): all mandated, yet none currently exist; the policy does not set creation deadlines. Administrative.
- 12.10.1-12.10.7 (full incident-response plan, annual test, 24/7 designated responders, training, alert handling, lessons learned, unexpected-PAN procedures): comprehensively stated, yet no plan, no roles, no 24/7 arrangement and no tested notification path currently exist. Administrative / Technical.
- No explicit coverage of 12.7.1 screening mechanics beyond the high-level statement (minor). Administrative.

No invented obligations or wrong version numbers were found; accuracy defects are limited to the operational gaps noted above.

**** 3. Scoring ****

**** Requirement 7 (Restrict access) ****

Applicable sub-requirements (checklist): 7.1.1, 7.1.2, 7.2.1, 7.2.2, 7.2.3, 7.2.4, 7.2.5, 7.2.5.1, 7.2.6 (9 items).

Ratings: Fully (3) × 7; Largely (2) × 2 (7.2.4 ownership/evidence; 7.2.5.1 risk-analysis frequency still undefined in practice).

Coverage points = 25 / 27 → Coverage = 93.

Accuracy defects = 0 → Accuracy = 95.

Proportionality = 90 (controls fit a two-person function and no-PAN CDE).

Enforceability = 75 (most obligations testable; isolated missing owners/frequencies).

Area score = $(93 \times 0.35) + (95 \times 0.25) + (90 \times 0.20) + (75 \times 0.20) = 32.55 + 23.75 + 18.00 + 15.00 = **89**$.

**** Requirement 8 (Identify users and authenticate) ****

Applicable sub-requirements: 8.1.1, 8.1.2, 8.2.1, 8.2.2, 8.2.4, 8.2.5, 8.2.6, 8.2.7, 8.2.8, 8.3.1, 8.3.3, 8.3.4, 8.3.5, 8.3.6, 8.3.7, 8.3.8, 8.3.9, 8.3.11, 8.4.1, 8.4.2, 8.4.3, 8.6.1, 8.6.2, 8.6.3 (24 items).

Ratings: Fully (3) × 20; Largely (2) × 4 (8.2.5/8.2.6 operational gap; 8.2.8 SaaS timeout; 8.3.6/8.4.x implementation deadlines absent).

Coverage points = 68 / 72 → Coverage = 94.

Accuracy defects = 0 → Accuracy = 95.

Proportionality = 85 (MFA and session controls correctly scoped; current tooling gaps noted but not over-claimed).

Enforceability = 70 (clear statements, but several lack named owners or completion dates).

Area score = $(94 \times 0.35) + (95 \times 0.25) + (85 \times 0.20) + (70 \times 0.20) = 32.90 + 23.75 + 17.00 + 14.00 = **88**$.

**** Requirement 10 (Log and monitor) ****

Applicable sub-requirements: 10.1.1, 10.1.2, 10.3.1, 10.4.1, 10.4.2, 10.4.2.1, 10.4.3, 10.5.1, 10.7.3 (9 items).

Ratings: Fully (3) × 6; Largely (2) × 3 (10.4.1 daily/out-of-hours mechanism; 10.4.2.1 risk-analysis frequency; 10.5.1 archival implementation).

Coverage points = 24 / 27 → Coverage = 89.

Accuracy defects = 0 → Accuracy = 95.

Proportionality = 80 (daily 24/7-style reviews stretch a two-person function; SIEM limitations correctly acknowledged).

Enforceability = 70 (obligations clear; owners and “how” for daily reviews and archival missing).

Area score = $(89 \times 0.35) + (95 \times 0.25) + (80 \times 0.20) + (70 \times 0.20) = 31.15 + 23.75 + 16.00 + 14.00 = **85**$.

****Requirement 12 (Organisational policies and programmes)****

Applicable sub-requirements: 12.1.1, 12.1.2, 12.1.3, 12.1.4, 12.2.1, 12.3.1, 12.3.2, 12.3.3, 12.3.4, 12.5.1, 12.5.2, 12.6.1, 12.6.2, 12.6.3, 12.6.3.1, 12.6.3.2, 12.7.1, 12.8.1, 12.8.2, 12.8.3, 12.8.4, 12.8.5, 12.10.1, 12.10.2, 12.10.3, 12.10.4, 12.10.4.1, 12.10.5, 12.10.6, 12.10.7 (30 items).

Ratings: Fully (3) × 22; Largely (2) × 6 (12.1.3 acknowledgement process; 12.3.3 inventory creation; 12.6.3 completion tracking; 12.8.x register/agreements; 12.10.3 24/7 designation; 12.10.1 plan existence); Partially (1) × 2 (12.7.1 screening detail; 12.3.1 actual analyses).

Coverage points = 80 / 90 → Coverage = 89.

Accuracy defects = 0 → Accuracy = 95.

Proportionality = 75 (24/7 IR coverage and full TPSP programme are ambitious for headcount of 61 / two security staff; scope statements correctly reflect no-PAN CDE).

Enforceability = 65 (many “shall” statements without owners, deadlines or evidence requirements).

Area score = $(89 \times 0.35) + (95 \times 0.25) + (75 \times 0.20) + (65 \times 0.20) = 31.15 + 23.75 + 15.00 + 13.00 = **83**$.

Policy-level score (arithmetic mean) = $(89 + 88 + 85 + 83) / 4 = **86**$.

****4. Remediation****

1. Immediately draft, approve and test a full incident-response plan (12.10.1–12.10.7) that designates 24/7 responders, includes acquirer/payment-brand notification paths, covers unexpected PAN discovery, and is exercised within 30 days. (Critical – Administrative/Technical)
2. Create and populate the TPSP register, obtain written security-responsibility acknowledgements, perform due diligence on all eleven suppliers, and produce the responsibility matrix (12.8.1–12.8.5) within 60 days. (Critical – Administrative)
3. Implement MFA for every non-console path into the CDE and all remote access that can impact the CDE; close the order-management session-timeout gap to enforce ≤15-minute idle re-authentication; raise all password minima to 12 characters where supported (8.4.x, 8.2.8, 8.3.6). (Critical – Technical)
4. Establish automated or tightly controlled manual joiner/mover/leaver processes that revoke access on termination the same day and disable inactive accounts within 90 days; extend the same controls to all SaaS platforms that touch the CDE (8.2.5, 8.2.6). (Major – Technical/Administrative)
5. Configure SIEM archival so that 12 months of audit logs are retained with the most recent three months immediately searchable; institute a documented daily (including weekends) log-review process for the 10.4.1 categories, with escalation outside office hours (10.5.1, 10.4.1). (Major – Technical)

6. Produce the missing targeted risk analyses for 7.2.5.1, 8.6.3, 10.4.2.1 and 12.10.4.1; create the cryptographic inventory and technology-lifecycle register; schedule the first six-monthly access reviews with management sign-off (12.3.1, 12.3.3, 12.3.4, 7.2.4). (Major – Administrative)
7. Update all job descriptions, roll out role-specific security training for support/finance/administrators, raise awareness-completion tracking to 100 %, and implement formal annual policy acknowledgements (12.1.3, 12.6.3). (Major – Administrative)
8. Assign named owners and evidence requirements to every remaining “shall” statement; correct any residual obsolete role titles; publish the next policy review date and approval record (12.1.2 and enforceability across all areas). (Minor – Administrative)

F.5.4 A(P1b) — Grok audits P1b

Run	A(P1b) — Grok audits P1b
Model	Grok
Build	Grok 4.5
Interface	Web interface
Date and time (BST)	22 August 2026, 02:15 BST
Purpose	Cross-audit of P1b
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Evaluation Rubric and Scoring Guide.docx; Scenario Brief NorthPay.docx
Prompt file used	PROMPT-C_Audit-of-P1b_ASSEMBLED_2026-08-22.txt
Output file	A(P1b)_Grok_PromptC_2026-08-22.txt
Refusal or truncation	None
Non-default settings	None

Verbatim output:

1. Mapping

1.1 Purpose: 7.1.1, 8.1.1, 10.1.1, 12.1.1–12.1.4

1.2 Payment environment and scope: 12.5.1, 12.5.2

1.3 UK GDPR relationship: (supports 12.10.1 legal analysis; not a direct PCI sub-requirement)

1.4 Regulatory boundary: (boundary statement; supports scope accuracy)

2.1 Executive accountability: 12.1.3, 12.1.4

2.2 Information Security Manager: 7.1.2, 8.1.2, 10.1.2, 12.1.3

2.3 Compliance Analyst: 7.1.2, 8.1.2, 10.1.2

2.4 System and business owners: 7.1.2, 7.2.2, 7.2.3
2.5 All personnel: 12.1.3, 12.6.3
3.1 Access control model: 7.1.1, 7.1.2, 7.2.1–7.2.3
3.2 Access requests and approval: 7.2.2, 7.2.3, 8.2.4
3.3 Legacy and unnecessary groups: 7.2.4
3.4 User access reviews: 7.2.4
3.5 Application and system accounts: 7.2.5, 7.2.5.1
3.6 Direct access to data repositories: 7.2.6
4.1 Unique identities: 8.1.1, 8.1.2, 8.2.1
4.2 Shared and generic accounts: 8.2.2
4.3 Joiners, movers and leavers: 8.2.4–8.2.6
4.4 Third-party remote accounts: 8.2.7
4.5 Session timeout: 8.2.8
4.6 Authentication requirements: 8.3.1, 8.3.3–8.3.9, 8.3.11
4.7 Authentication guidance: 8.3.8
4.8 Multi-factor authentication: 8.4.1–8.4.3
4.9 System and application authentication: 8.6.1–8.6.3
5.1 Logging responsibilities: 10.1.1, 10.1.2, 10.3.1
5.2 Central logging: 10.3.1, 10.4.1
5.3 Daily review: 10.4.1
5.4 Other log reviews: 10.4.2, 10.4.2.1
5.5 Anomalies and exceptions: 10.4.3
5.6 Log protection and retention: 10.3.1, 10.5.1
5.7 Time consistency: (supports 10.4 reviewability)
5.8 Failure of critical security controls: 10.7.3
6.1 Policy management: 12.1.1–12.1.4
6.2 Policy acknowledgement: 12.1.3, 12.6.3
6.3 Acceptable use of end-user technology: 12.2.1
7.1 Targeted Risk Analysis: 12.3.1
7.2 Customized approach: 12.3.2
7.3 Cryptographic inventory and review: 12.3.3
7.4 Technology review: 12.3.4
8.1 System inventory: 12.5.1
8.2 Annual and change-driven scope validation: 12.5.2
9.1 Security awareness programme: 12.6.1–12.6.3
9.2 Training content: 12.6.3.1, 12.6.3.2
9.3 Role-specific training: 12.6.1, 12.10.4
9.4 Personnel screening: 12.7.1
10.1 TPSP register: 12.8.1
10.2 Written agreements: 12.8.2
10.3 Due diligence: 12.8.3
10.4 Annual monitoring: 12.8.4
10.5 Responsibility matrix: 12.8.5
10.6 UK GDPR intersection: (supports 12.8 and 12.10 legal)

11.1 Incident Response Plan: 12.10.1
 11.2 Incident reporting by personnel: 12.10.1
 11.3 24/7 response availability: 12.10.3
 11.4 Incident-response training: 12.10.4, 12.10.4.1
 11.5 Monitoring-system alerts: 12.10.5
 11.6 Annual test and review: 12.10.2, 12.10.6
 11.7 Unexpected discovery of PAN: 12.10.7
 11.8 PCI DSS and UK GDPR incident coordination: 12.10.1 (legal analysis)
 12.1–12.3: (supports data minimisation, retention, transfers; intersects 12.5, 12.10)
 13.1–13.3: (supports evidence, change, findings; intersects 12.5, 12.10)
 14.1–14.2: (exceptions and enforcement; supports 12.1 enforceability)
 15 / 15.1 / 15.2: 7.1.1, 8.1.1, 10.1.1, 12.1.1, 12.1.2

2. Findings

- 7.2.5.1 / 8.6.3 / 10.4.2.1 / 12.10.4.1: TRA required but no completed TRA register or examples exist in the organisation context; policy states the obligation without evidence of performance (A)
- 8.2.8: Session timeout stated as required (>15 min) but organisation currently has 60-min AWS and indefinite order-management sessions; remediation is only “shall be remediated” without owner/date (T)
- 8.3.6 / 8.3.9: Current identity-provider minimum is 10 characters and 90-day expiry; policy correctly requires 12 characters and addresses the single-factor case, but the increase and any MFA-based exception remain unimplemented (T)
- 8.4.1–8.4.3: MFA currently enforced only on AWS console and collaboration suite; policy correctly expands the requirement but technical enforcement on order-management, PSP portal and other CDE-impacting paths is still absent (T)
- 8.2.5 / 8.2.6: Immediate revocation and 90-day inactivity stated; organisation still relies on manual SaaS de-provisioning with no automatic process (A/T)
- 10.4.1 / 10.5.1: Daily review and 12-month retention stated; SIEM currently retains only 90 days searchable and no offline archive exists; order-management admin log not forwarded (T)
- 10.4.1: High-severity alerts currently limited to working-hours mailbox; policy requires 24/7 reachability but no on-call rota or technical routing is in place (A/T)
- 12.1.1–12.1.4 / 12.6.3: Policy itself is new; prior template policies had no owner, approval signature or 12-month review evidence; current training completion is 78 % (A)
- 12.3.1 / 12.3.3 / 12.3.4: TRA, cryptographic inventory and technology review obligations stated; organisation currently has none of these artefacts (A)
- 12.5.1 / 12.5.2: Scope inventory and annual validation required; no formal inventory or data-flow diagrams currently maintained (A)
- 12.8.1–12.8.5: Full TPSP programme required; organisation has no register, no written security acknowledgements, no due-diligence process and no responsibility matrix (A)
- 12.10.1–12.10.7: Complete IRP required; organisation currently has no written incident-response plan, no 24/7 contacts, no tested notification path to acquirer and no PAN-discovery procedure (A)
- 12.7.1: Screening required for CDE access; no evidence of current pre-employment screening process (A)

- Legislative intersection (UK GDPR 72-hour notification, retention schedules, Dublin transfer documentation): addressed in policy but no internal procedure or records exist (L)

3. Scoring

Requirement 7 (9 applicable sub-requirements)

Checklist: 7.1.1 Fully(3); 7.1.2 Fully(3); 7.2.1 Fully(3); 7.2.2 Fully(3); 7.2.3 Fully(3); 7.2.4 Fully(3); 7.2.5 Fully(3); 7.2.5.1 Largely(2 – TRA frequency defined but no performed TRA); 7.2.6 Fully(3). Sum = 26.

Coverage = $100 \times 26 / 27 \approx 96$.

Accuracy defects: 0. Accuracy = 95.

Proportionality = 90 (two-person function, no-PAN CDE correctly reflected).

Enforceability = 85 (owners and six-monthly cadence clear; TRA still prospective).

Area score = $(96 \times 0.35) + (95 \times 0.25) + (90 \times 0.20) + (85 \times 0.20) = 33.6 + 23.75 + 18 + 17 = 92.35 \rightarrow 92$

Requirement 8 (24 applicable)

Checklist: 8.1.1 Fully(3); 8.1.2 Fully(3); 8.2.1 Fully(3); 8.2.2 Fully(3); 8.2.4 Fully(3); 8.2.5 Fully(3); 8.2.6 Fully(3); 8.2.7 Fully(3); 8.2.8 Largely(2 – requirement stated, current configurations non-compliant); 8.3.1 Fully(3); 8.3.3 Fully(3); 8.3.4 Fully(3); 8.3.5 Fully(3); 8.3.6 Largely(2 – 12-char required, current 10-char); 8.3.7 Fully(3); 8.3.8 Fully(3); 8.3.9 Fully(3); 8.3.11 Fully(3); 8.4.1 Largely(2); 8.4.2 Largely(2); 8.4.3 Largely(2); 8.6.1 Fully(3); 8.6.2 Fully(3); 8.6.3 Largely(2 – TRA frequency). Sum = 66. Coverage = $100 \times 66 / 72 \approx 92$.

Accuracy defects: 0. Accuracy = 95.

Proportionality = 85 (MFA expansion and timeout remediation realistic for size).

Enforceability = 80 (most obligations owned; technical gaps remain open).

Area score = $(92 \times 0.35) + (95 \times 0.25) + (85 \times 0.20) + (80 \times 0.20) = 32.2 + 23.75 + 17 + 16 = 88.95 \rightarrow 89$

Requirement 10 (9 applicable)

Checklist: 10.1.1 Fully(3); 10.1.2 Fully(3); 10.3.1 Fully(3); 10.4.1 Largely(2 – daily review stated, current working-hours only + no archive); 10.4.2 Fully(3); 10.4.2.1 Largely(2 – TRA required); 10.4.3 Fully(3); 10.5.1 Largely(2 – 12-month required, only 90-day SIEM); 10.7.3 Fully(3). Sum = 24.

Coverage = $100 \times 24 / 27 \approx 89$.

Accuracy defects: 0. Accuracy = 95.

Proportionality = 85 (no 24/7 SOC demanded; on-call acceptable).

Enforceability = 75 (owners clear; retention and continuous alert routing still missing).

Area score = $(89 \times 0.35) + (95 \times 0.25) + (85 \times 0.20) + (75 \times 0.20) = 31.15 + 23.75 + 17 + 15 = 86.9 \rightarrow 87$

Requirement 12 (30 applicable)

Checklist (summarised by group): 12.1.1–12.1.4 Fully(3 each = 12); 12.2.1 Fully(3); 12.3.1 Largely(2); 12.3.2 Fully(3); 12.3.3 Largely(2); 12.3.4 Largely(2); 12.5.1 Largely(2); 12.5.2 Largely(2); 12.6.1 Fully(3); 12.6.2 Fully(3); 12.6.3 Fully(3); 12.6.3.1 Fully(3); 12.6.3.2 Fully(3); 12.7.1 Fully(3); 12.8.1–12.8.5 Largely(2 each = 10); 12.10.1 Largely(2); 12.10.2 Largely(2); 12.10.3 Fully(3); 12.10.4 Fully(3); 12.10.4.1 Largely(2); 12.10.5 Fully(3); 12.10.6 Fully(3); 12.10.7 Fully(3). Sum = 78. Coverage = $100 \times 78 / 90 \approx 87$.

Accuracy defects: 0. Accuracy = 95.

Proportionality = 85 (two-person security function, SAQ A-EP, no-PAN CDE respected; 24/7 on-call not full SOC).

Enforceability = 75 (clear owners and cadences; many artefacts still absent in practice).

Area score = $(87 \times 0.35) + (95 \times 0.25) + (85 \times 0.20) + (75 \times 0.20) = 30.45 + 23.75 + 17 + 15 = 86.2 \rightarrow 86$

Policy-level score (arithmetic mean) = $(92 + 89 + 87 + 86) / 4 = 88.5 \rightarrow 89$

4. Remediation

1. (Critical) Draft, approve and test a complete Incident Response Plan (12.10.1–12.10.7) including named 24/7 contacts, acquirer notification path, PAN-discovery procedure and dual PCI/UK-GDPR assessment; perform first tabletop exercise within 30 days.
2. (Critical) Enforce MFA via the central identity provider on every non-console path that can access or impact the CDE (order-management platform, PSP merchant portal, administrative consoles) and apply conditional-access rules blocking unmanaged devices (8.4.1–8.4.3).
3. (Critical) Increase identity-provider password minimum to 12 characters, confirm lock-out and history settings, and remediate all in-scope session timeouts to ≤ 15 minutes idle (8.3.6, 8.2.8).
4. (Major) Implement protected 12-month audit-log archive (searchable 3 months + offline remainder) and forward or formally assign daily review of the order-management administrator log; configure high-severity alerts to reach the 24/7 on-call rota outside office hours (10.4.1, 10.5.1).
5. (Major) Create and populate the single TPSP register, obtain written security acknowledgements, perform due diligence on the 11 existing suppliers, and produce the PCI DSS responsibility matrix for the PSP and cloud services (12.8.1–12.8.5).
6. (Major) Produce the first set of Targeted Risk Analyses (7.2.5.1, 8.6.3, 10.4.2.1, 12.10.4.1), cryptographic inventory (12.3.3) and technology lifecycle review (12.3.4); schedule annual refreshes.
7. (Major) Build and maintain the formal PCI DSS scope inventory and data-flow diagrams; complete first annual scope validation (12.5.1, 12.5.2).
8. (Major) Automate or tightly control joiner/mover/leaver de-provisioning across all SaaS platforms that touch the CDE; enforce 90-day inactivity disablement (8.2.5, 8.2.6).
9. (Major) Raise security-awareness completion to 100 % (with documented exceptions only) and deliver role-specific modules for administrators, customer support and finance; record annual policy acknowledgements (12.6.3).
10. (Minor) Document UK-GDPR retention schedules for support tickets, marketing lists and logs, record the Dublin backup transfer under the UK adequacy decision, and map the 72-hour ICO notification path inside the IRP (Legislative support to 12.10).

F.5.5 A(P2a) — ChatGPT audits P2a

Run	A(P2a) — ChatGPT audits P2a
Model	ChatGPT
Build	GPT-5.6 Sol
Interface	Web interface
Date and time (BST)	22 August 2026, 02:20 BST

Purpose	Cross-audit of P2a
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Evaluation Rubric and Scoring Guide.docx; Scenario Brief NorthPay.docx
Prompt file used	PROMPT-C_Audit-of-P2a_ASSEMBLED_2026-08-22.txt
Output file	A(P2a)_ChatGPT_PromptC_2026-08-22.txt
Refusal or truncation	None
Non-default settings	None

Verbatim output:

1. Mapping

Basis: P2a has been mapped only to the NorthPay scenario, PCI DSS v4.0.1 requirements, and RUB-01 supplied in the source material.

Policy provision	PCI DSS requirement addressed

1. Purpose and Scope	Cross-cutting scope statement supporting 12.1.1 and 12.5.2; establishes applicability of Requirements 7, 8, 10 and 12
2.1.1	7.1.1
2.1.2	7.1.2
2.2.1	7.2.1
2.3.1	7.2.2
2.3.2	7.2.3
2.4.1-2.4.3	7.2.4
2.5.1	7.2.5
2.5.2-2.5.3	7.2.5.1
2.6.1-2.6.2	7.2.6
3.1.1	8.1.1
3.1.2	8.1.2
3.2.1	8.2.1
3.2.2	8.2.2
3.2.3	8.2.4
3.2.4	8.2.5

3.2.5	8.2.6	
3.2.6	8.2.7	
3.2.7	8.2.8	
3.3.1	8.3.1	
3.3.2	8.3.3	
3.3.3	8.3.4	
3.3.4	8.3.5	
3.3.5	8.3.6	
3.3.6	8.3.7	
3.3.7	8.3.8	
3.3.8	8.3.9	
3.3.9	8.3.11	
3.4.1	8.4.1	
3.4.2	8.4.2	
3.4.3	8.4.3	
3.5.1	8.6.1	
3.5.2	8.6.2	
3.5.3	8.6.3	
4.1.1	10.1.1	
4.1.2	10.1.2	
4.2.1	10.3.1	
4.3.1	10.4.1	
4.3.2	10.4.2	
4.3.3	10.4.2.1	
4.3.4	10.4.3	
4.4.1	10.5.1	
4.5.1	10.7.3	
5.1.1	12.1.1	
5.1.2	12.1.2	
5.1.3	12.1.3	
5.1.4	12.1.4	
5.2.1	12.2.1	
5.3.1	12.3.1	
5.3.2	12.3.2	
5.3.3	12.3.3	
5.3.4	12.3.4	
5.4.1	12.5.1	
5.4.2	12.5.2	
5.5.1	12.6.1	
5.5.2	12.6.2	
5.5.3	12.6.3	
5.5.4	12.6.3.1	
5.5.5	12.6.3.2	
5.6.1	12.7.1	

5.7.1	12.8.1	
5.7.2	12.8.2	
5.7.3	12.8.3	
5.7.4	12.8.4	
5.7.5	12.8.5	
5.8.1	12.10.1	
5.8.2	12.10.2	
5.8.3	12.10.3	
5.8.4	12.10.4 and 12.10.4.1	
5.8.5	12.10.5	
5.8.6	12.10.6	
5.8.7	12.10.7	
6. Policy Review and Maintenance 12.1.2 and the annual acknowledgement element of 12.6.3		

2. Findings

RUB-01 requires each finding to carry a Prioritized Approach-based severity. The supplied material does not provide the milestone allocation for the individual sub-requirements. Assigning Critical/Major/Minor would therefore require importing information not supplied in the audit source. Severity is recorded as ****ND**** below rather than inventing that mapping.

ID	Requirement	Finding
Tag	Severity	
---	-----	

F1	7.1.2, 8.1.2, 10.1.2, 12.1.3	The policy repeatedly states that roles and responsibilities “are documented, assigned, and understood” but does not actually identify the operational roles responsible for access administration, authentication, log review, incident response, supplier oversight, training, or risk analysis.
Administrative	ND	
F2	7.2.1–7.2.5.1	Access-control obligations are substantively correct but lack named control owners. The Information Security Manager is the document owner, not expressly the person accountable for each provisioning, approval, review and remediation action.
Administrative	ND	
F3	7.2.4	Six-monthly access review is stated correctly, but no reviewer, system owner, evidence requirement, escalation route or deadline for removal of inappropriate access is defined. This is material given the three obsolete project groups that still contain members.
Administrative	ND	
F4	7.2.5.1	Application/system-account reviews depend on a targeted risk analysis, but NorthPay has no documented targeted risk analysis. Consequently the policy

supplies no currently operable review frequency.

| Administrative | ND |

| F5 | 7.2.6 | The policy speaks unconditionally of “repositories of stored cardholder data.” NorthPay does not store full PAN or other CHD on its systems. The provision should either be expressly conditional/not applicable to the present architecture or distinguish unexpected PAN discovery from normal storage. |

Technical / Administrative | ND |

| F6 | 8.2.4-8.2.6 | Joiner/mover/leaver controls are correctly stated but no lifecycle owner or operating procedure is identified. NorthPay currently removes SaaS access manually and has no automatic de-provisioning, making immediate revocation dependent on an unstated manual process. |

Administrative / Technical | ND |

| F7 | 8.2.8 | The 15-minute re-authentication rule is correctly reproduced but is not connected to a responsible system owner or enforcement mechanism. Current AWS administrative sessions allow 60 minutes and the order-management session does not time out while its tab remains open. |

Technical | ND |

| F8 | 8.3.6 | The required 12-character password minimum is correctly stated, but no owner is made responsible for reconciling the policy with the identity provider's existing 10-character minimum.

| Technical | ND |

| F9 | 8.4.1-8.4.3 | MFA requirements are correctly reproduced but no accountable owner, rollout mechanism or exception/remediation process is identified. NorthPay currently enforces MFA only for AWS and the collaboration suite, despite other systems being capable of impacting the CDE. |

Technical / Administrative | ND |

| F10 | 8.6.3, 12.3.1 | System/application account password-change frequency is delegated to a targeted risk analysis that does not currently exist, leaving the operative frequency undefined.

| Technical / Administrative | ND |

| F11 | 10.3.1 | Log-read access is restricted to persons with a job-related need, but the policy neither defines the authorised log-reader roles nor requires periodic review of those permissions.

| Technical / Administrative | ND |

| F12 | 10.4.1 | Daily review is correctly mandated, but no person or team is responsible for performing and evidencing that review. Current monitoring consists of selected alerts to a mailbox watched only 08:00-18:00 on working days.

| Technical / Administrative | ND |

| F13 | 10.4.2, 10.4.2.1 | Review of other logs is described only as “periodic”; its actual cadence depends on a targeted risk analysis that NorthPay has not produced.

| Administrative | ND |

| F14 | 10.4.1-10.4.3 | The policy does not address how the order-management platform's separate administrator log is brought into the review process, even though it is not

forwarded to the SIEM.

| Technical | ND |

| F15 | 10.5.1 | The 12-month retention requirement is stated accurately but no owner or storage method is identified. NorthPay currently retains only 90 days and has no separate archive.

| Technical | ND |

| F16 | 10.7.3 | The security-control-failure response wording is complete, but no responder, escalation path, evidencing mechanism or link to the incident-response structure is defined.

| Administrative / Technical | ND |

| F17 | 12.1.3 | The policy does not actually define security responsibilities "for all personnel"; it merely states that they are defined. This is inconsistent with the scenario in which engineering and support job descriptions contain no security responsibilities.

| Administrative | ND |

| F18 | 12.1.4 | The policy does not formally assign executive responsibility to a named individual. It states that responsibility is assigned to a CISO or another knowledgeable executive, while the front matter names the non-executive Information Security Manager as policy owner and the scenario says the CTO's PCI ownership is undocumented.

| Administrative | ND |

| F19 | 12.2.1 | The policy states that an acceptable-use policy exists and contains prescribed elements, but does not itself identify the approved technologies, acceptable uses, approving authority or control over personal devices. Current BYOD restrictions are enforced only by convention.

| Administrative / Technical | ND |

| F20 | 12.3.1 | The targeted-risk-analysis methodology is accurately restated but no role is assigned to create, approve, retain or annually review the analyses. NorthPay currently has none.

| Administrative | ND |

| F21 | 12.3.3 | The cryptographic inventory and annual review are required but no custodian is identified. NorthPay currently has no inventory of algorithms, protocols, certificates, key locations or key holders.

| Technical / Administrative | ND |

| F22 | 12.3.4 | Annual technology review is accurately required but lacks a responsible owner and defined evidence record.

| Administrative / Technical | ND |

| F23 | 12.5.1–12.5.2 | Scope inventory and annual/significant-change validation are well described, but no scoping owner is named and no responsibility is assigned for maintaining the component inventory or data-flow diagrams.

| Administrative | ND |

| F24 | 12.6.1–12.6.3.2 | Awareness requirements are substantially complete, but there is no training owner or mechanism for following up non-completion. The existing annual course achieved only 78% completion.

| Administrative | ND |

| F25 | 12.7.1 | Pre-employment screening is required but there is no named HR/management owner, evidence requirement or exception process within the limits of local law.
| Administrative | ND |

| F26 | 12.8.1–12.8.5 | The five TPSP obligations are reproduced accurately but no supplier-management owner or operating workflow is specified. NorthPay currently has no complete supplier register, pre-contract due diligence, annual PCI-status monitoring or responsibility matrix.
| Administrative | ND |

| F27 | 12.10.1 | The incident-response requirement is reproduced, but the policy does not itself designate incident roles, contacts, escalation authority or acquirer/payment-brand contact paths. NorthPay currently has no security incident-response plan.
| Administrative | ND |

| F28 | 12.10.1 | The phrase “analysis of legal requirements for reporting compromises” is too generic for NorthPay’s known legal environment. It does not map the UK GDPR requirement to notify the ICO within 72 hours where the statutory criteria are met, nor coordinate that clock with acquirer notification.
Legislative / Administrative | ND |

| F29 | 12.10.2 | Annual IR review and testing are stated, but no test owner, test method, evidence record or remediation process is assigned.
| Administrative | ND |

| F30 | 12.10.3 | The policy says “specific personnel are designated” for 24/7 response but does not designate them. This is not testable from the policy.
| Administrative | ND |

| F31 | 12.10.4–12.10.4.1 | Incident responders must be trained periodically, but no responders are named and the training cadence depends on a targeted risk analysis that does not exist.
| Administrative | ND |

| F32 | 12.10.5 | Alert-response categories are listed, but responsibility for receiving, triaging and escalating those alerts is absent; the current shared mailbox is not monitored 24/7.
| Technical / Administrative | ND |

| F33 | 12.10.6 | “Modified and evolved according to lessons learned” states the objective but does not define who conducts lessons-learned reviews or when changes must be made.
| Administrative | ND |

| F34 | Cross-cutting 7.1.1, 8.1.1, 10.1.1, 12.1.1–12.1.2 | P2a declares numerous procedures to be documented, current and “in use,” but the scenario records outdated template policies, no formal review cycle, and several absent processes. The policy contains no implementation/effective-control mechanism for reconciling those declarations with actual practice. This is an enforceability/implementation weakness, not an RUB-01 accuracy defect. | Administrative | ND |

No finding is recorded for an FCA obligation: P2a correctly makes no claim that NorthPay is FCA-regulated.

3. Scoring

The RUB-01 calibration exercise cannot be completed from the supplied source because the worked examples and reference scores referred to in Sections D.8 and D.9 are not included. The live scoring below therefore does not claim successful calibration. No score has been adjusted to compensate for that omission.

Requirement 7

Sub-requirement	Rating	Points	Evidence note where below Fully
7.1.1	Fully addressed	3	—
7.1.2	Partially addressed	1	Named roles absent
7.2.1	Largely addressed	2	Operational owner absent
7.2.2	Largely addressed	2	Access-assignment owner absent
7.2.3	Largely addressed	2	Authorised approver role absent
7.2.4	Largely addressed	2	Review owner absent
7.2.5	Largely addressed	2	System-account owner absent
7.2.5.1	Largely addressed	2	Review owner/operative TRA frequency absent
7.2.6	Largely addressed	2	Owner absent; stored-CHD wording not tailored to NorthPay

****Checklist total:**** 18 points out of 27.

****Coverage:**** $(100 \times 18 / 27 = 66.67)$, rounded once = ****67****.

****Accuracy defects: 0.**** The supplied Requirement 7 clauses are correctly represented; the stored-CHD scope issue is a proportionality/scope-fit issue, not an RUB-01 accuracy defect.

Criterion	Score	Basis
Regulatory coverage	67	Checklist result
Accuracy	90	No counted defect; midpoint of 81–100 band
Proportionality and scope fit	75	Broadly operable, but 7.2.6 assumes a stored-CHD repository not present in NorthPay's normal architecture
Enforceability and clarity	55	Obligations and six-month cadence are generally testable, but operational ownership is largely absent and TRA-dependent cadence is not presently determinable

****Requirement 7 score:****

$$(67 \times 0.35 + 90 \times 0.25 + 75 \times 0.20 + 55 \times 0.20 = \mathbf{71.95})$$

Requirement 8

Sub-requirement	Rating	Points	Evidence note where below Fully
-----	-----:	----	-----
8.1.1	Fully addressed	3	—
8.1.2	Partially addressed	1	Named roles absent
8.2.1	Largely addressed	2	Account-provisioning owner absent
8.2.2	Largely addressed	2	Exception administrator/approver role absent
8.2.4	Largely addressed	2	Authorising role absent
8.2.5	Largely addressed	2	Termination/de-provisioning owner absent
8.2.6	Largely addressed	2	Inactive-account review owner absent
8.2.7	Largely addressed	2	Third-party account owner/monitor absent
8.2.8	Largely addressed	2	Enforcement owner absent
8.3.1	Largely addressed	2	Authentication-control owner absent
8.3.3	Largely addressed	2	Identity-verification owner/process absent
8.3.4	Largely addressed	2	Lockout-control owner absent
8.3.5	Largely addressed	2	Password-reset owner absent
8.3.6	Largely addressed	2	Password-policy owner absent
8.3.7	Largely addressed	2	Password-history control owner absent
8.3.8	Largely addressed	2	Communication owner absent
8.3.9	Largely addressed	2	Control owner absent
8.3.11	Largely addressed	2	Token/certificate owner absent
8.4.1	Largely addressed	2	MFA owner absent
8.4.2	Largely addressed	2	MFA owner absent
8.4.3	Largely addressed	2	Remote-access MFA owner absent
8.6.1	Largely addressed	2	Exception owner/approver not identified
8.6.2	Largely addressed	2	Credential-management owner absent
8.6.3	Largely addressed	2	Owner and operative TRA frequency absent

Checklist total: 48 points out of 72.

Coverage: $(100 \times 48 / 72 = 66.67)$, rounded once = **67**.

Accuracy defects: 0. Password, lockout, inactivity, MFA and system-account parameters correspond to the supplied PCI DSS v4.0.1 text.

Criterion	Score	Basis
-----	----	

Regulatory coverage	67 Checklist result
Accuracy	90 No counted defect
Proportionality and scope fit	70 Controls are broadly suitable for NorthPay and its federated IdP, but the policy does not reconcile several mandates with the stated SaaS/session/MFA environment
Enforceability and clarity	60 Numerical parameters are highly testable; lack of named lifecycle, MFA and authentication owners prevents entry into the 61-80 band

****Requirement 8 score:****

$(67 \times 0.35 + 90 \times 0.25 + 70 \times 0.20 + 60 \times 0.20 = \mathbf{71.95})$

Requirement 10

Sub-requirement	Rating	Points	Evidence note where below Fully	
-----	-----:	----:	-----	
10.1.1	Fully addressed	3	—	
10.1.2	Partially addressed	1	Named roles absent	
10.3.1	Largely addressed	2	Log-access owner absent	
10.4.1	Largely addressed	2	Daily-review owner absent	
10.4.2	Largely addressed	2	Reviewer absent	
10.4.2.1	Largely addressed	2	Operative TRA frequency/owner absent	
10.4.3	Largely addressed	2	Exception-remediation owner absent	
10.5.1	Largely addressed	2	Retention owner absent	
10.7.3	Largely addressed	2	Failure-response owner absent	

****Checklist total:**** 18 points out of 27.

****Coverage:**** $(100 \times 18 / 27 = 66.67)$, rounded once = ****67****.

****Accuracy defects: 0.**** Daily review, 12-month retention/three-month availability and control-failure response are correctly stated.

Criterion	Score	Basis
-----	----:	

Regulatory coverage	67 Checklist result
Accuracy	90 No counted defect

| Proportionality and scope fit | 55 | NorthPay has a SIEM, but the policy assumes capabilities not presently in place, particularly 12-month retention and a complete review process covering separate SaaS logs |

| Enforceability and clarity | 55 | Frequencies and retention parameters are clear, but reviewers, escalation owners and TRA-derived cadence are not assigned |

Requirement 10 score:

$(67 \times 0.35 + 90 \times 0.25 + 55 \times 0.20 + 55 \times 0.20 = \mathbf{67.95})$

Requirement 12

Sub-requirement	Rating	Points	Evidence note where below Fully
-----	-----:	-----:	-----
12.1.1	Fully addressed	3	—
12.1.2	Fully addressed	3	—
12.1.3	Partially addressed	1	Actual personnel responsibilities absent
12.1.4	Partially addressed	1	Named knowledgeable executive absent
12.2.1	Largely addressed	2	AUP owner absent
12.3.1	Largely addressed	2	TRA owner absent
12.3.2	Largely addressed	2	Customized-approach analysis owner absent
12.3.3	Largely addressed	2	Cryptographic inventory/review owner absent
12.3.4	Largely addressed	2	Technology-review owner absent
12.5.1	Largely addressed	2	Inventory custodian absent
12.5.2	Largely addressed	2	Scoping owner absent
12.6.1	Largely addressed	2	Awareness-program owner absent
12.6.2	Largely addressed	2	Review owner absent
12.6.3	Largely addressed	2	Training/completion owner absent
12.6.3.1	Largely addressed	2	Training owner absent
12.6.3.2	Largely addressed	2	Training owner absent
12.7.1	Largely addressed	2	Screening owner absent
12.8.1	Largely addressed	2	TPSP-register owner absent
12.8.2	Largely addressed	2	Contract-control owner absent
12.8.3	Largely addressed	2	Due-diligence owner absent
12.8.4	Largely addressed	2	Annual monitoring owner absent
12.8.5	Largely addressed	2	Responsibility-matrix owner absent
12.10.1	Largely addressed	2	IR-plan owner/actual roles absent
12.10.2	Largely addressed	2	Test owner absent
12.10.3	Partially addressed	1	“Specific personnel” not designated
12.10.4	Largely addressed	2	Training owner absent
12.10.4.1	Largely addressed	2	Operative TRA frequency absent
12.10.5	Largely addressed	2	Monitoring/response owner absent
12.10.6	Largely addressed	2	Lessons-learned owner/cadence absent

| 12.10.7 | Largely addressed | 2 | PAN-discovery response owner absent |

****Checklist total:**** 59 points out of 90.

****Coverage:**** $(100 \times 59 / 90 = 65.56)$, rounded once = ****66****.

****Accuracy defects: 0.**** No supplied Requirement 12 obligation is invented, materially misrepresented, attached to a clearly incorrect number, or expressed using a superseded parameter.

| Criterion | Score | Basis

|
| ----- | ----: |

| Regulatory coverage | 66 | Checklist result

|
| Accuracy | 90 | No counted defect

|
| Proportionality and scope fit | 55 | The controls are generally relevant but remain template-like and assume several organisational processes NorthPay does not currently possess: TRA, TPSP governance, 24/7 incident coverage, formal incident response and cryptographic inventory |

| Enforceability and clarity | 45 | Numerous provisions say a process “is implemented” or personnel “are designated” without identifying those people, actual supporting processes or owners
|

****Requirement 12 score:****

$(66 \times 0.35 + 90 \times 0.25 + 55 \times 0.20 + 45 \times 0.20 = \mathbf{65.60})$

Aggregate scoring record

| Requirement area | Coverage | Accuracy | Proportionality | Enforceability | Weighted score |

| ----- | ----: | ----: | -----: | -----: | -----: |

| Requirement 7 | 67 | 90 | 75 | 55 | ****71.95**** |

| Requirement 8 | 67 | 90 | 70 | 60 | ****71.95**** |

| Requirement 10 | 67 | 90 | 55 | 55 | ****67.95**** |

| Requirement 12 | 66 | 90 | 55 | 45 | ****65.60**** |

Policy-level arithmetic mean:

[
(71.95 + 71.95 + 67.95 + 65.60) / 4
= 69.3625
]

Policy-level score: 69/100 — “Substantial, with only minor gaps” under the D.4 numerical band, although the underlying findings include important operational and ownership weaknesses. In accordance with RUB-01, the score has not been altered to reconcile that numerical result with the qualitative impression.

4. Remediation

1. **Turn Requirement 12 incident-response wording into an actual NorthPay incident-response structure.** Formally appoint an incident-response owner and named 24/7 responders; document acquirer/payment-brand contacts, containment procedures, recovery, backups, monitoring escalation and unexpected-PAN procedures; incorporate the UK GDPR/ICO 72-hour decision path; test the plan at least annually and retain evidence.
2. **Close the Requirement 8 configuration gaps against the policy immediately.** Enforce MFA for all access capable of accessing or impacting the CDE, not only AWS and collaboration; change the identity-provider minimum from 10 to at least 12 characters; enforce re-authentication after more than 15 minutes of inactivity; and establish an immediate termination/de-provisioning process across federated and non-federated SaaS accounts.
3. **Remediate Requirement 10 log retention and review.** Extend audit-log history to at least 12 months while keeping the latest three months immediately available; bring the order-management administrator log into a defined review process; assign a named daily reviewer or function; document anomaly escalation and evidence of reviews.
4. **Formally assign control ownership rather than relying on the Information Security Manager's document-owner label.** Create a responsibility matrix covering access provisioning and approval, account reviews, IAM configuration, log review, risk analysis, PCI scope, awareness, TPSPs, incident response and technology/cryptography reviews. Record executive responsibility for information security explicitly, consistent with 12.1.4.
5. **Complete the required targeted risk analyses under 12.3.1.** At minimum, establish the analyses needed to determine the frequency of application/system-account access reviews under 7.2.5.1, system/application account password changes under 8.6.3, other-system log reviews under 10.4.2.1, and incident-responder training under 12.10.4.1. Assign an owner, annual review date and management evidence.
6. **Establish the TPSP programme required by 12.8.** Build the single supplier register; identify all TPSPs able to affect account-data security; obtain appropriate contractual acknowledgements; perform due diligence before engagement; verify PCI DSS status annually; and maintain a responsibility matrix showing NorthPay, TPSP and shared PCI responsibilities.
7. **Implement the six-month access-review process and clear existing stale access.** Assign system owners, review all users and privileged users, include vendor accounts, require management

acknowledgement, remove inappropriate membership, and specifically review the three obsolete project groups still carrying members.

8. **Create and maintain the cryptographic and technology inventories.** Record protocols, cipher suites, certificates, purposes, locations and responsible holders; replace the single-engineer certificate spreadsheet with an owned control record; conduct and evidence the annual viability review and technology/end-of-life review required by 12.3.3 and 12.3.4.

9. **Formalise PCI scope management.** Assign a scoping owner and maintain the in-scope component inventory and data-flow diagrams covering checkout/payment initiation, authorisation result/token flow, settlement, disputes/refunds, third-party connections, backup locations and segmentation. The policy should expressly reflect NorthPay's A-EP architecture in which full PAN does not normally enter or reside on NorthPay systems.

10. **Tailor 7.2.6 to NorthPay's actual data architecture.** State that NorthPay presently has no repository of stored full PAN; make the direct-query restriction conditional on such a repository existing, while retaining 12.10.7 procedures for unexpected PAN discovery. This removes the implication that normal NorthPay systems store CHD.

11. **Create a practical acceptable-use standard.** Identify approved company hardware/software, authorised uses, personal-device restrictions and the approval authority. Convert the present convention preventing personal devices from reaching CDE-impacting systems into an enforceable technical/conditional-access rule.

12. **Strengthen security-awareness governance.** Assign an awareness owner; require training on hire and annually; ensure acknowledgement; cover phishing, social engineering and acceptable use; track completion to closure rather than accepting the current 78%; and separately establish periodic training for incident-response personnel.

13. **Introduce an auditable personnel-screening process for CDE-access roles.** Assign responsibility to the appropriate recruitment/HR function, define evidence and exceptions within UK legal constraints, and ensure screening occurs before access is granted.

14. **Revise P2a from a standards restatement into an operational policy.** Keep its generally accurate PCI DSS parameters, but for each recurring or actionable obligation identify the accountable role, required evidence, frequency, approval authority and exception handling. Remove declarative phrases such as "roles are assigned" where the document does not actually make the assignment.

F.5.6 A(P2b) — ChatGPT audits P2b

Run	A(P2b) — ChatGPT audits P2b
Model	ChatGPT

Build	GPT-5.6 Sol
Interface	Web interface
Date and time (BST)	22 August 2026, 02:30 BST
Purpose	Cross-audit of P2b
Instrument files	Prompt Library.docx; Requirement Text Extract PCI DSS v4.0.1 Requirements 7, 8, 10, 12.docx; Evaluation Rubric and Scoring Guide.docx; Scenario Brief NorthPay.docx
Prompt file used	PROMPT-C_Audit-of-P2b_ASSEMBLED_2026-08-22.txt
Output file	A(P2b)_ChatGPT_PromptC_2026-08-22.txt
Refusal or truncation	None
Non-default settings	None

Verbatim output:

1. Mapping

The mapping below audits P2b as written against the supplied PCI DSS v4.0.1 requirements and the NorthPay scenario.

Policy provision	Requirement/sub-requirement addressed
-----	-----
Document Control: owner, approver, annual review, publication, acknowledgement	7.1.1; 8.1.1; 10.1.1; 12.1.1; 12.1.2; 12.6.3
1. Purpose and Scope: systems that connect to/can impact payment security	12.5.1; 12.5.2; supports scope application of Requirements 7, 8 and 10
1. No full PAN/SAD stored, processed or transmitted by NorthPay	Scope/proportionality context for 7, 8, 10 and 12.5
1. UK GDPR/DPA overlap	Legislative overlay; supports but does not replace PCI DSS controls
2. CTO executive ownership	12.1.4
2. Information Security Manager responsibilities	7.1.2; 8.1.2; 10.1.2; 12.1.3

2. Compliance Analyst responsibilities	12.1.3; 12.6; 12.8	
2. Line-manager responsibilities	7.2.3; 7.2.4; 8.2.4; 8.2.5	
2. All-personnel responsibilities	12.1.3; 12.6.1; 8.3.8; 12.10	
2. Head of Finance and Legal	Legislative incident-reporting overlay;	
12.10.1 legal-reporting analysis		
3.1 Least privilege/job classification	7.2.1; 7.2.2	
3.2 Access request, approval and implementation	7.2.3; also supports 8.2.4	
3.3 Six-monthly account/privilege review	7.2.4	
3.4 Application/system-account least privilege	7.2.5	
3.4 Periodic system-account review using TRA	7.2.5.1; 12.3.1	
3.5 Controlled application/direct repository access	7.2.6	
3.6 Customer-record least privilege	7.2.1/7.2.2 plus UK GDPR overlay	
4.1 Unique identifiers	8.2.1	
4.1 Shared/generic account exceptions	8.2.2	
4.2 Approved account/authentication changes	8.2.4	
4.3 Terminated/inactive accounts	8.2.5; 8.2.6	
4.4 Third-party remote accounts	8.2.7	
4.5 15-minute idle timeout	8.2.8	
4.6 Authentication factors	8.3.1	
4.7 First-use/reset passwords	8.3.5	
4.7 Password length/complexity	8.3.6	
4.7 Password history	8.3.7	
4.7 90-day single-factor rule/risk-based alternative	8.3.9	
4.8 Lockout	8.3.4	
4.9 MFA	8.4.1; 8.4.2; 8.4.3	

4.10 Individual authentication factors	8.3.11	
4.11 Interactive application/system accounts	8.6.1	
4.11 No hard-coded passwords	8.6.2	
4.11 Periodic/change-on-compromise system-account passwords	8.6.3; 12.3.1	
4.12 Authentication guidance	8.3.8	
5.1 Audit logging	General Requirement 10 logging objective	
5.2 Restricted log read access	10.3.1	
5.3 Daily log review	10.4.1	
5.4 Periodic other-log review	10.4.2; 10.4.2.1; 12.3.1	
5.5 Exceptions/anomalies	10.4.3	
5.6 12-month/three-month retention	10.5.1	
5.7 Critical-security-control failures	10.7.3	
5.7 GDPR log-retention language	Legislative overlay	
6.1 Overall policy	12.1.1; 12.1.2	
6.2 Acceptable-use rules	12.2.1	
6.3 Targeted risk analyses	12.3.1	
6.4 In-scope component inventory	12.5.1	
6.4 Annual/change-triggered scoping	12.5.2	
6.5 Formal awareness programme	12.6.1	
6.5 Training content/review	12.6.2; 12.6.3; 12.6.3.1; 12.6.3.2	
6.6 Pre-employment screening	12.7.1	
6.7 TPSP register	12.8.1	
6.7 TPSP agreements	12.8.2	

6.7 Due diligence	12.8.3	
6.7 Annual PCI-status monitoring	12.8.4	
6.7 responsibility matrix	12.8.5	
6.8 Incident-response plan contents	12.10.1	
6.8 Annual review/test	12.10.2	
6.8 24/7 designated personnel	12.10.3	
6.8 responder training/TRA	12.10.4; 12.10.4.1	
6.8 monitoring/response to security alerts	12.10.5	
6.8 lessons learned/industry developments	12.10.6	
6.8 unexpected PAN procedures	12.10.7	
6.8 ICO/acquirer/payment-brand paths overlay	12.10.1 plus UK GDPR legislative overlay	
7. Review and Enforcement	12.1.2; supports 7.1.1, 8.1.1 and 10.1.1	
8. Related Documents and 12	Evidence/supporting artefacts for 7, 8, 10 and 12	

2. Findings

1. **Requirement 8.3.3 — identity verification before authentication-factor changes is absent.**
 Section 4.2 requires approval before modification but never requires verification of the requesting user's identity before an authentication factor is changed. **Tag: Technical/Administrative. Severity: Major.**

2. **Requirements 12.3.3 and 12.3.4 — cryptographic and technology reviews are absent.** The policy does not require an annual inventory/review of cipher suites and protocols, monitoring of their continued viability, a response plan for cryptographic weaknesses, or annual review of hardware/software supportability and end-of-life status. This is especially material because NorthPay presently has no cryptographic inventory. **Tag: Technical/Administrative. Severity: Major.**

3. **Requirement 12.5.2 — annual PCI scoping validation is materially abbreviated.** Section 6.4 names data flows, account-data locations, system components, segmentation and third-party connections, but does not expressly require updating data-flow diagrams, checking locations outside the currently defined CDE and backups, documenting justification for out-of-scope environments, or

confirming that every identified flow/component/connection is included. **Tag: Administrative. Severity: Major.**

4. **Requirement 12.2.1 — acceptable-use content is incomplete.** Section 6.2 states that acceptable-use rules exist but does not expressly require authorized approval or a maintained list of company-approved hardware and software. **Tag: Administrative. Severity: Major.**

5. **Requirement 12.6.2 — annual review of the awareness programme itself is not stated.** Annual personnel training and annual policy review are specified, but the awareness programme is not expressly required to be reviewed annually and updated for new threats and vulnerabilities. **Tag: Administrative. Severity: Major.**

6. **Requirement 12.10.5 — incident-monitoring coverage is too generic.** “Monitoring and response to alerts from security systems” does not expressly encompass the listed sources, including network security controls, critical-file change detection, payment-page change/tamper detection and unauthorized wireless-access-point detection. **Tag: Technical/Administrative. Severity: Major.**

7. **Requirement 8.6.3 — system-account password complexity is incomplete.** Section 4.11 states the TRA-defined change frequency and change upon suspected compromise, but does not require complexity appropriate to that frequency. **Tag: Technical. Severity: Major.**

8. **Requirement 8.3.8 — compromise instructions are incomplete.** Section 4.12 requires reporting suspected compromise but does not explicitly instruct users to change a password/passphrase where compromise is suspected or known. **Tag: Administrative. Severity: Minor.**

9. **Requirement 8.2.2 — shared-account exception controls omit an explicit identity-verification step.** The policy makes exceptional use attributable to an individual but does not expressly require confirmation of that individual's identity before access is granted. **Tag: Technical/Administrative. Severity: Minor.**

10. **Requirements 7.1.1, 8.1.1 and 10.1.1 — supporting operational procedures are not demonstrably established.** The policy itself is documented and current, but it does not establish that all associated Requirement 7/8/10 operational procedures are documented, current, in use and known to affected parties. **Tag: Administrative. Severity: Minor.**

11. **Requirement 7.2.5.1 — remediation of inappropriate application/system-account access is implicit rather than explicit.** Section 3.4 requires review and management acknowledgement but omits the express requirement that inappropriate application/system-account access identified by that review be addressed. **Tag: Administrative/Technical. Severity: Minor.**

12. **Requirement 8.2.8 — policy and operating environment conflict.** Section 4.5 correctly mandates re-authentication after 15 minutes, but the scenario says order-management sessions

currently remain active while the browser tab is open and administrative console sessions time out after 60 minutes. The policy is compliant wording but is not presently enforceable across the stated environment. **Tag: Technical. Severity: Major.**

13. **Requirements 8.4.1–8.4.3 — policy and MFA implementation conflict.** Section 4.9 correctly states the PCI requirement, but MFA is presently enforced only for AWS and the collaboration suite. The order-management platform, PSP portal and other relevant paths therefore lack evidence that the stated policy has been implemented. **Tag: Technical. Severity: Major.**

14. **Requirements 8.2.5/8.2.6 — lifecycle enforcement is weak.** The policy requires immediate termination and 90-day inactivity handling, but NorthPay has no automatic de-provisioning and SaaS removal is manual. Manual operation is not itself prohibited, but evidence is needed that the stated deadlines are consistently achieved. **Tag: Administrative/Technical. Severity: Minor.**

15. **Requirement 10.5.1 — current log retention directly conflicts with the policy.** Section 5.6 correctly requires 12 months with three months immediately available, while the current SIEM deletes/overwrites logs after 90 days and has no archive. **Tag: Technical. Severity: Major.**

16. **Requirements 10.4.1–10.4.3 — the daily-review control lacks demonstrated operating coverage.** Alerts currently reach a mailbox monitored only 08:00–18:00 on working days, and the order-management administrator log is not forwarded to the SIEM. The policy states the required daily reviews but does not explain how NorthPay will reliably execute them across all relevant sources. **Tag: Technical/Administrative. Severity: Major.**

17. **Requirement 12.3.1 — TRA wording is sound but the required analyses do not presently exist.** This makes the frequencies delegated to TRA in 7.2.5.1, 8.6.3, 10.4.2.1 and 12.10.4.1 operationally undefined until the analyses are completed. **Tag: Administrative. Severity: Major.**

18. **Requirement 12.8 — the policy describes a TPSP programme that the organisation does not presently operate.** The scenario states that there is no supplier register, engagement due diligence, annual review or responsibility matrix. Sections 6.7 therefore state appropriate controls but do not establish an operating programme. **Tag: Administrative. Severity: Major.**

19. **Requirement 12.10 — the policy describes an incident-response capability that does not presently exist.** NorthPay currently has no security-specific incident-response plan, assigned card-compromise roles or tested acquirer-notification path. The policy alone cannot discharge these operational requirements. **Tag: Administrative/Technical. Severity: Major.**

20. **Requirement 12.10.3 — 24/7 availability needs an operable on-call mechanism.** The policy appropriately requires designated personnel rather than unnecessarily requiring a 24/7 SOC, which is proportionate for NorthPay, but no rota, escalation mechanism or equivalent arrangement is identified. **Tag: Administrative. Severity: Minor.**

21. **Requirement 12.6 — training is not yet operating at the policy's stated level.** The current 78% annual completion rate and absence of role-specific training conflict with section 6.5. **Tag: Administrative. Severity: Major.**

22. **Requirement 12.2.1 — personal-device restriction is not currently technically enforced.** Section 6.2 says conditional access enforces the restriction, whereas the scenario states it is presently enforced only by convention. **Tag: Technical. Severity: Major.**

23. **UK GDPR retention governance remains incomplete.** Section 5.7 promises documented retention schedules within three months, but the scenario has no defined retention periods for support tickets, marketing lists or log data. The forward commitment is useful but does not itself establish the required governance. **Tag: Legislative/Administrative. Severity: Minor.**

24. **UK GDPR/card-compromise notification integration is not presently operational.** Section 6.8 correctly calls for mapped ICO and PCI/acquirer paths, but the scenario confirms no internal procedure capable of reliably meeting the statutory 72-hour process and no tested relationship between the two notification paths. **Tag: Legislative/Administrative. Severity: Major.**

No FCA obligation is asserted, which is consistent with the supplied organisational boundary.

3. Scoring

Requirement 7

Sub-requirement	Rating	Evidence note where below Fully
-----	-----	

7.1.1	Largely addressed — 2	Policy is controlled/current, but all associated operational procedures are not expressly required to be documented, current, in use and known.
7.1.2	Fully addressed — 3	—
7.2.1	Fully addressed — 3	—
7.2.2	Fully addressed — 3	—
7.2.3	Fully addressed — 3	—
7.2.4	Fully addressed — 3	—
7.2.5	Fully addressed — 3	—

7.2.5.1	Largely addressed — 2	“Any inappropriate access is addressed” is not expressly included for application/system-account reviews.
7.2.6	Not applicable	NorthPay does not maintain repositories of stored CHD/full PAN; excluded from denominator.

Coverage: $22/24 = 92/100$.

Accuracy defects: 0 . The policy's Requirement 7 controls do not invent obligations, use superseded parameters or materially misstate the supplied requirements.

Criterion	Score
Regulatory coverage	92
Accuracy	100
Proportionality and scope fit	90
Enforceability and clarity	90

Requirement 7 score: $(92 \times 0.35) + (100 \times 0.25) + (90 \times 0.20) + (90 \times 0.20) = 93/100$.

Requirement 8

Sub-requirement	Rating	Evidence note where below Fully
8.1.1	Largely addressed — 2	Associated operational procedures are not expressly covered by the document-control obligation.
8.1.2	Fully addressed — 3	—
8.2.1	Fully addressed — 3	—
8.2.2	Largely addressed — 2	Exceptional shared-account wording does not explicitly require identity confirmation before access.
8.2.4	Fully addressed — 3	—
8.2.5	Fully addressed — 3	—
8.2.6	Fully addressed — 3	—
8.2.7	Fully addressed — 3	—
8.2.8	Fully addressed — 3	Policy explicitly states 15 minutes, although current implementation conflicts with it.

8.3.1	Fully addressed — 3	—
8.3.3	Not addressed — 0	**Absent:** verification of identity before modifying an authentication factor.
8.3.4	Fully addressed — 3	—
8.3.5	Fully addressed — 3	—
8.3.6	Fully addressed — 3	—
8.3.7	Fully addressed — 3	—
8.3.8	Largely addressed — 2	Reporting compromise is required, but an explicit instruction to change the compromised password/passphrase is missing.
8.3.9	Fully addressed — 3	—
8.3.11	Fully addressed — 3	—
8.4.1	Fully addressed — 3	—
8.4.2	Fully addressed — 3	—
8.4.3	Fully addressed — 3	—
8.6.1	Fully addressed — 3	—
8.6.2	Fully addressed — 3	—
8.6.3	Largely addressed — 2	Password complexity appropriate to the chosen change frequency is omitted.

Coverage: $65/72 = 90/100$.

Accuracy defects: 0 . The numerical password, lockout, inactivity and MFA parameters stated in the policy correspond to the supplied v4.0.1 requirements.

Criterion	Score
-----	----:
Regulatory coverage	90
Accuracy	100
Proportionality and scope fit	90
Enforceability and clarity	90

Requirement 8 score: $(90 \times 0.35) + (100 \times 0.25) + (90 \times 0.20) + (90 \times 0.20) = 93/100$.

The high policy score should not be read as evidence of operating compliance: the scenario's 60-minute/indefinite sessions and incomplete MFA deployment are significant implementation exceptions.

Requirement 10

Sub-requirement	Rating	Evidence note where below Fully
-----	-----	
10.1.1	Largely addressed — 2	Requirement 10 operational procedures are not expressly required to satisfy all four document-control conditions.
10.1.2	Fully addressed — 3	—
10.3.1	Fully addressed — 3	—
10.4.1	Fully addressed — 3	—
10.4.2	Fully addressed — 3	—
10.4.2.1	Fully addressed — 3	—
10.4.3	Fully addressed — 3	—
10.5.1	Fully addressed — 3	—
10.7.3	Fully addressed — 3	—

Coverage: 26/27 = **96/100**.

Accuracy defects: **0.** The daily/periodic review distinction and 12-month/three-month retention parameters correctly reproduce the supplied requirements.

Criterion	Score
-----	----
Regulatory coverage	96
Accuracy	100
Proportionality and scope fit	90
Enforceability and clarity	90

Requirement 10 score: $(96 \times 0.35) + (100 \times 0.25) + (90 \times 0.20) + (90 \times 0.20) = 95/100$.

Again, the policy is materially stronger than the operating state: 90-day actual retention, incomplete log centralisation and business-hours-only alert handling remain implementation findings.

Requirement 12

Sub-requirement	Rating	Evidence note where below Fully
-----	-----	
12.1.1	Fully addressed — 3	—
12.1.2	Fully addressed — 3	—
12.1.3	Fully addressed — 3	—
12.1.4	Fully addressed — 3	—
12.2.1	Partially addressed — 1	Acceptable-use controls are stated, but explicit authorized approval and a defined approved-product list are not required.
12.3.1	Fully addressed — 3	—
12.3.2	Not applicable	No customized approach is stated; policy uses the supplied Defined Approach requirements.
12.3.3	Not addressed — 0	**Absent:** annual cryptographic cipher-suite/protocol inventory, viability monitoring and response plan.
12.3.4	Not addressed — 0	**Absent:** annual technology support/EOL review and senior-management-approved remediation planning.
12.5.1	Fully addressed — 3	—
12.5.2	Partially addressed — 1	Several mandatory scoping-validation elements are condensed or omitted.
12.6.1	Fully addressed — 3	—
12.6.2	Partially addressed — 1	Annual review/update of the awareness programme itself is not stated.
12.6.3	Fully addressed — 3	—
12.6.3.1	Fully addressed — 3	—
12.6.3.2	Fully addressed — 3	—
12.7.1	Fully addressed — 3	—

12.8.1	Fully addressed — 3	—
12.8.2	Fully addressed — 3	—
12.8.3	Fully addressed — 3	—
12.8.4	Fully addressed — 3	—
12.8.5	Fully addressed — 3	—
12.10.1	Fully addressed — 3	—
12.10.2	Fully addressed — 3	—
12.10.3	Fully addressed — 3	—
12.10.4	Fully addressed — 3	—
12.10.4.1	Fully addressed — 3	—
12.10.5	Largely addressed — 2	Security-alert monitoring is stated generically rather than expressly covering the listed monitoring mechanisms.
12.10.6	Fully addressed — 3	—
12.10.7	Fully addressed — 3	—

Coverage: $74/87 = 85/100$.

Accuracy defects: **0.** No PCI obligation is invented or assigned a superseded parameter; the UK GDPR 72-hour statement is appropriately qualified by the statutory notification criteria, and no unsupported FCA duty is asserted.

Criterion	Score
-----	----:
Regulatory coverage	85
Accuracy	100
Proportionality and scope fit	85
Enforceability and clarity	85

Requirement 12 score: $(85 \times 0.35) + (100 \times 0.25) + (85 \times 0.20) + (85 \times 0.20) = 89/100$.

Overall scoring record

Area	Checklist	Coverage	Accuracy defects	Accuracy	Proportionality	Enforceability	Weighted score
	-----	-----	-----	-----	-----	-----	-----
Requirement 7	22/24	92	0	100	90	90	**93**
Requirement 8	65/72	90	0	100	90	90	**93**
Requirement 10	26/27	96	0	100	90	90	**95**
Requirement 12	74/87	85	0	100	85	85	**89**

****Policy-level score:**** $(93 + 93 + 95 + 89) \div 4 = \mathbf{93/100}$.

The result reflects the rubric's distinction between ****policy coverage**** and ****actual operating effectiveness****. P2b is a comparatively complete policy text, but NorthPay's stated current environment contains substantial implementation gaps that would require evidence and remediation before the controls could be treated as operating.

4. Remediation

- **Close the live authentication gaps first.**** Enforce MFA across every applicable order-management, PSP, helpdesk, administrative and remote-access path under 8.4.1–8.4.3; reduce all applicable idle-session limits to 15 minutes; implement reliable leaver/inactivity controls; and add mandatory identity verification before authentication-factor resets.
- **Implement compliant log retention and daily review.**** Extend or archive logs so at least 12 months are retained and the latest three months are immediately available. Bring relevant SaaS administrator logs into the monitoring process or establish an equivalent documented review. Define an owned daily review process and escalation for anomalies and critical-control failures.
- **Create and activate the incident-response programme.**** Produce the referenced plan rather than relying on the policy declaration. Assign named roles and an achievable 24/7 on-call arrangement, document containment/recovery procedures, payment-brand/acquirer contacts, ICO assessment and notification paths, unexpected-PAN handling and monitoring-system alerts. Exercise the complete plan and retain evidence.
- **Complete the targeted risk analyses immediately.**** Establish the 12.3.1 methodology and complete TRAs for every entity-defined frequency, including application/system-account access reviews, system-account password changes, periodic log reviews and incident-responder training. Obtain documented annual review evidence.
- **Establish the TPSP programme.**** Inventory all relevant suppliers, identify those that can affect account-data security, collect the required contractual acknowledgements, perform documented due diligence, obtain and review PCI compliance evidence annually, and create the NorthPay/TPSP/shared-responsibility matrix.

6. **Add 12.3.3 and 12.3.4 to the policy and operating programme.** Maintain a current cryptographic inventory covering protocols, cipher suites, purpose and location; review viability annually and monitor industry developments. Separately maintain a technology inventory with support/EOL status, annual review and senior-management-approved remediation plans.
7. **Expand the annual PCI scoping procedure.** Require explicit identification of all payment flows—including authorization, settlement, disputes/refunds and backups—current data-flow diagrams, all connected/security-impacting components, segmentation controls and out-of-scope justification, third-party connections, and documented confirmation that the resulting scope is complete.
8. **Strengthen acceptable-use governance.** Have acceptable-use rules formally approved, maintain an approved hardware/software list, define permitted uses, and technically enforce the personal-device prohibition through conditional access rather than convention.
9. **Complete the awareness programme.** Move from 78% to evidenced completion for all personnel, ensure training occurs at hire and annually, formally review the programme annually for new threats, retain acknowledgements, and introduce the promised role-specific training for administrators and dispute-handling personnel.
10. **Amend the smaller Requirement 7 and 8 wording gaps.** Explicitly require remediation of inappropriate application/system-account privileges under 7.2.5.1; identity confirmation for exceptional shared-account use; changing compromised passwords under 8.3.8; and system-account password complexity appropriate to the TRA-defined change frequency under 8.6.3.
11. **Extend document governance to operational procedures.** State explicitly that all Requirement 7, 8 and 10 procedures—not merely the overarching policy—must be documented, current, in use, communicated to affected parties, owned and reviewed when their associated controls or environment change.
12. **Finish the overlapping UK GDPR controls.** Establish documented retention schedules for support tickets, marketing information and logs; document the Dublin backup transfer; and integrate the ICO breach-assessment process with the PCI/acquirer incident process so the statutory 72-hour decision and applicable card-industry notifications can be managed concurrently.